

Mapeo de objetivos GQM y métricas SIEM a requisitos normativos

Versión 1.0 – Mapeo orientativo para NIS2, ENS, DORA y buenas prácticas ISO.

1. Tabla de mapeo GQM-normativa

Objetivo / Métrica	NIS2 (art.)	ENS (dominio)
DORA / Sectorial	Comentario de alineamiento básico	
----- ----- -----		
----- ----- -----		
G1 - Reducir MTDD/MTTR en incidentes	21, 23	Operación, gestión
incidentes Resiliencia operativa	Soporta gestión de incidentes y	
continuidad en servicios esenciales.		
M1.1 MTDD incidentes críticos	21(2)	Operación, monitorización
Detección	Mide rapidez de detección frente a amenazas.	
M1.2 MTTR hasta contención	21(2),(3)	Gestión de incidentes
Recuperación	Refleja capacidad de respuesta y contención.	
M1.3 Distribución MTDD por tipo incidente	21(2)	Idem
Escenarios	Introduce granularidad por tipología de amenaza.	
G2 - Cumplimiento notificación NIS2/ENS	23	Gestión de incidentes
Requisitos de reporte	Asegura plazos y calidad de notificación.	
M2.1 Plazo detección-notificación	23(1)-(4)	Registro & comunicación
Plazos de reporte	KPI directo de diligencia en notificación.	
M2.2% incidentes en plazo	23(1)-(4)	Idem
Idem	Indica cumplimiento operativo de la norma.	
M2.3 Índice completitud evidencias	23(4)	Registro de actividad
Evidencias para supervisores	Evalúa solidez de la prueba técnica aportada.	
G3 - Calidad y cobertura de monitorización	21(2),(3)	Inventario, operación
Gestión de activos críticos	Centrado en activos esenciales IT/OT/5G.	
M3.1% activos críticos monitorizados	21(2)	Inventario de activos
Inventario TIC crítico	Muestra qué parte del riesgo se ve realmente.	
M3.2% técnicas ATT&CK cubiertas	21(2)	Análisis de amenazas
Escenarios de riesgo	Alinea casos de uso con amenazas relevantes.	
M3.3 Latencia ingesta eventos críticos	21(2)	Monitorización
Supervisión continua	Garantiza visibilidad casi en tiempo real.	
G4 - Uso efectivo de IA y automatización	21(2)	Operación, eficiencia
Optimización de controles	Apoya la escalabilidad y reduce errores humanos.	
M4.1% detecciones impulsadas por IA	21(2)	Mejora de detección
Tecnologías avanzadas	Indica grado de dependencia y aportación de	
modelos avanzados.		
M4.2% incidentes con respuesta automatiz.	21(2),(3)	Gestión de incidentes
Automatización de respuesta	Relaciona SOAR con eficiencia y rapidez.	
M4.3 Δ% falsos positivos tras IA	21(2)	Eficacia de controles
Calidad de detección	Mide impacto directo de IA sobre calidad de	
alertas.		
G5 - Integración SIEM-riesgo y ROI	21(2),(3)	Gestión de riesgos
Gestión del riesgo TIC	Conecta SIEM con decisiones de inversión y	
apetito de riesgo.		
M5.1% comités de riesgo con métricas SIEM	21(3)	Organización de la
seguridad Gobierno TIC	Mide integración de seguridad en la	
gobernanza.		

M5.2 Frecuencia anual de incidentes graves	21(2),(3)	Análisis de riesgos
Indicadores de riesgo		Permite estimar exposición residual.
M5.3 Estimación de pérdidas evitadas (€)	21(3)	Proporcionalidad medidas
Evaluación coste-beneficio		Justifica inversiones en controles de seguridad.

2. Uso del mapeo

- Facilitar la conversación entre equipos técnicos, jurídicos y de cumplimiento.
- Priorizar métricas que aportan valor directo a las obligaciones normativas.
- Vincular los resultados de la encuesta SIEM con los ejercicios de auditoría y supervisión.

Fin del mapeo.